

CIBERSEGURANÇA APLICADA COM IA · AULA 09

# Qual o custo de um *falso positivo* em um SOC? E de um *falso negativo*?

*Limiar de decisão, custo operacional, validação e viés · base da avaliação intermediária.*

DISCIPLINA

Cibersegurança com IA

UNIDADE

Avaliação intermediária

AULA

09

```
python3 · sklearn · threshold sweep

>>> y_score = model.predict_proba(X)[: , 1]
>>> for t in [0.15, 0.30, 0.50, 0.80]:
...     p, r = pr_at(y, y_score, t)
...     custo = fp(t)*12 + fn(t)*2500
t=0.15 P=0.71 R=0.90 custo=R$ 2.624 ← min
t=0.30 P=0.86 R=0.85 custo=R$ 3.100
t=0.50 P=1.00 R=0.70 custo=R$ 4.682
t=0.80 P=1.00 R=0.55 custo=R$ 6.900
# o modelo dá a pontuação · você escolhe o corte
>>> _
```

# Onde estamos: da *medida* à decisão

O MODELO DEVOLVE UMA PONTUAÇÃO.  
HOJE DECIDIMOS O CORTE.

## ROTEIRO 1

### Regras à mão

Detecção escrita como regras explícitas.

## ROTEIRO 2

### Classificador + split temporal

Modelo que devolve uma pontuação.

## AULA PASSADA

### Matriz, P/R/F1, ROC × PR

Como medir um classificador.

## HOJE · AVALIAÇÃO

### Limiar, custo, validação, viés

Como transformar medida em decisão.

O modelo do Roteiro 2 devolve uma pontuação. Alguém decidiu que **0,5** é o corte. Hoje discutimos quem decide isso e com que critério.

Três perguntas do gestor: quantos alertas vou receber, quanto custa cada erro, e o número que você me mostrou **vale para a semana que vem?**

*A avaliação intermediária é assíncrona, individual ou em dupla, e reaproveita o modelo do Roteiro 2 · não pede modelo novo.*

O TURNO DA NOITE, ANTES DE QUALQUER MODELO

# Uma noite no SOC

10.000

alertas por dia em um SOC de porte médio

8 min

de um analista N1 por alerta triado

> 160

analistas necessários para triar tudo

## O QUE ACONTECE DE VERDADE

- › O time desliga regras barulhentas e sobe limiares até o volume caber
- › Alertas viram fila; a fila vira ignorar
- › O ataque real chega junto com 300 falsos e passa

## A PERGUNTA QUE O MODELO NÃO RESPONDE

- › Onde cortar a pontuação para que o volume caiba no time
- › Quanto vale um ataque que passa, comparado a 8 minutos de analista
- › Esses dois números decidem o limiar; o modelo só fornece a pontuação

STALLINGS · POR QUE A MÉTRICA DE LABORATÓRIO ENGANA

## A falácia da *taxa-base*

### O CENÁRIO

- › 1 ataque a cada 10.000 fluxos · prevalência 0,01%
- › Detector com recall de 99%
- › Taxa de falsos positivos de apenas 1%

### A CONTA

- › Ataques detectados: 0,99
- › Alertas falsos: 1% de 9.999  $\approx$  100
- › Precisão:  $0,99 \div 101 \approx 1\%$

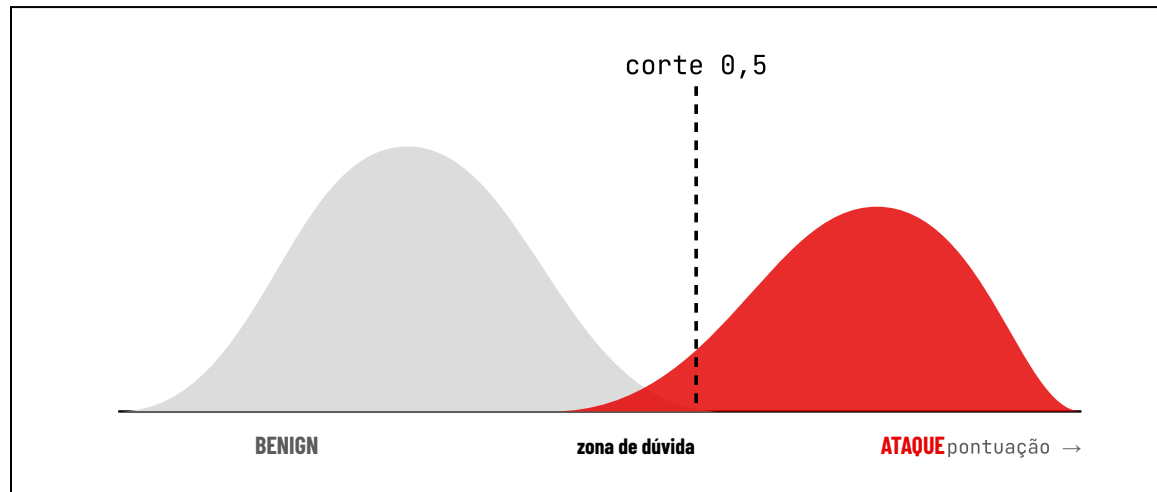
1%

dos alertas são ataques reais

*Um detector "99% / 1%" é excelente no laboratório e inútil no turno da noite. Quanto mais rara a classe, menos a ROC enxerga o problema · a curva Precision-Recall é a curva do SOC.*

O 0,5 É O DEFAULT DA BIBLIOTECA, NÃO UMA DECISÃO DE SEGURANÇA

# O modelo não decide. O *limiar* decide.



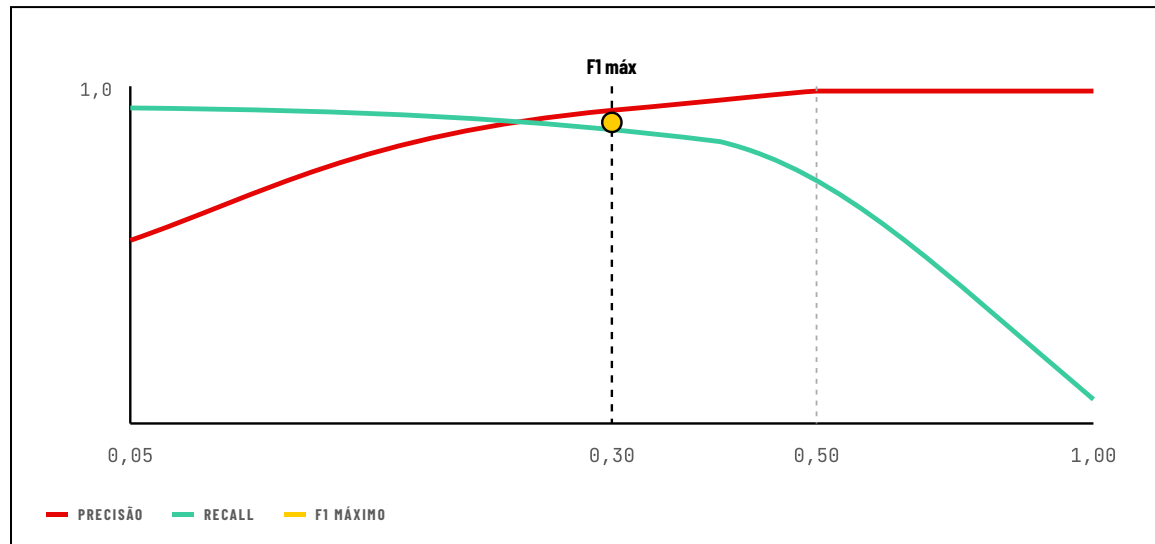
## COMO LER

- › **predict() = predict\_proba() ≥ 0,5.** O 0,5 é o default da biblioteca, não uma decisão de segurança.
- › Se o corte passa por uma região povoada, cada centésimo de limiar move alertas de lado.
- › O limiar é um **botão de operação**. Quem gira é quem sabe o custo do erro e o tamanho do time.

Item b) · desenhe esse histograma com o seu modelo

O MESMO MODELO, DEZENOVE DECISÕES

## Varredura de *limiar*



### LEITURA

- › De 0,05 a 0,20 a precisão vai de **0,54 a 0,90** e o recall quase não cai
- › Acima de 0,50: precisão 1,0, recall despencando
- › F1 máximo em **0,30**
- › Nenhum desses pontos é "o certo" sem saber o que cada erro custa

Item d) · `varrer_limiares()` reutilizável

ROC E PR DISCORDAM · EM QUAL VOCÊ ACREDITA?

# As duas áreas *discordam*

| MODELO        | ROC-AUC | PR-AUC | FP EM 0,5 | FN EM 0,5 | PRECISÃO 0,5 | RECALL 0,5 |
|---------------|---------|--------|-----------|-----------|--------------|------------|
| Random Forest | 0,937   | 0,814  | 0         | 32        | 1,000        | 0,704      |
| XGBoost       | 0,985   | 0,803  | 24        | 25        | 0,776        | 0,769      |

0 0,5 NÃO É O MESMO 0,5

- › RF em 0,5: **nenhum** alerta falso, 32 fraudes passam
- › XGB em 0,5: 24 alertas falsos, 25 fraudes passam
- › scale\_pos\_weight empurra as pontuações do XGB para cima

## POR QUE DISCORDAM

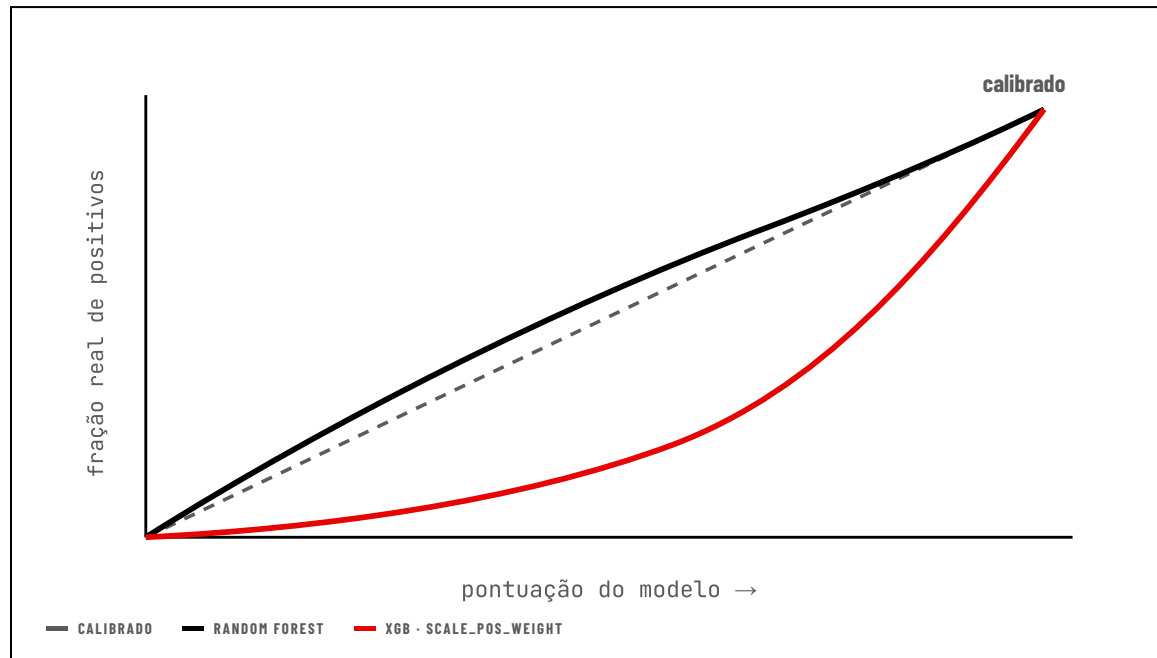
- › ROC: eixo x é FP ÷ 85.331 legítimas · 24 falsos positivos não movem nada
- › PR: eixo y é TP ÷ alertas · 24 falsos positivos em 107 alertas movem muito
- › Com 0,13% de prevalência, a PR é a curva do SOC · itens c) e g)

## CONSEQUÊNCIA

- › Comparar modelos no corte 0,5 é comparar **dois limiares diferentes**
- › O XGB "ganha" na ROC e "perde" na PR · nenhum número está errado
- › A pergunta certa é qual eixo reflete o custo do seu turno

QUANDO A PONTUAÇÃO VIRA PROBABILIDADE

# Calibração · 0,5 não quer dizer 50%



## TRÊS REGRAS

- › Um modelo é calibrado quando, entre os pontuados com 0,7, cerca de **70%** são positivos.
- › **Regra 1** · nunca comparar modelos em um corte fixo; comparar pela varredura.
- › **Regra 2** · se a pontuação vira probabilidade (custo esperado por alerta), calibrar antes: `CalibratedClassifierCV`.
- › **Regra 3** · retreinou, recalibrou. A escala muda com o modelo.

CADA ERRO TEM UM PREÇO

# Matriz de *custo*

$$\text{custo total} = \text{FP} \times \text{C\_FP} + \text{FN} \times \text{C\_FN}$$

| CENÁRIO                    | FALSO POSITIVO CUSTA            | FALSO NEGATIVO CUSTA                   | RAZÃO C_FN ÷ C_FP |
|----------------------------|---------------------------------|----------------------------------------|-------------------|
| SOC de intrusão · Parte A  | R\$ 12 · 8 min de analista N1   | R\$ 2.500 · contenção de incidente     | ≈ 200             |
| Fraude em cartão · Parte B | R\$ 5 · confirmar com o cliente | Valor da transação que passou · Amount | varia por linha   |

## O QUE O MODELO DÁ E O QUE O NEGÓCIO DÁ

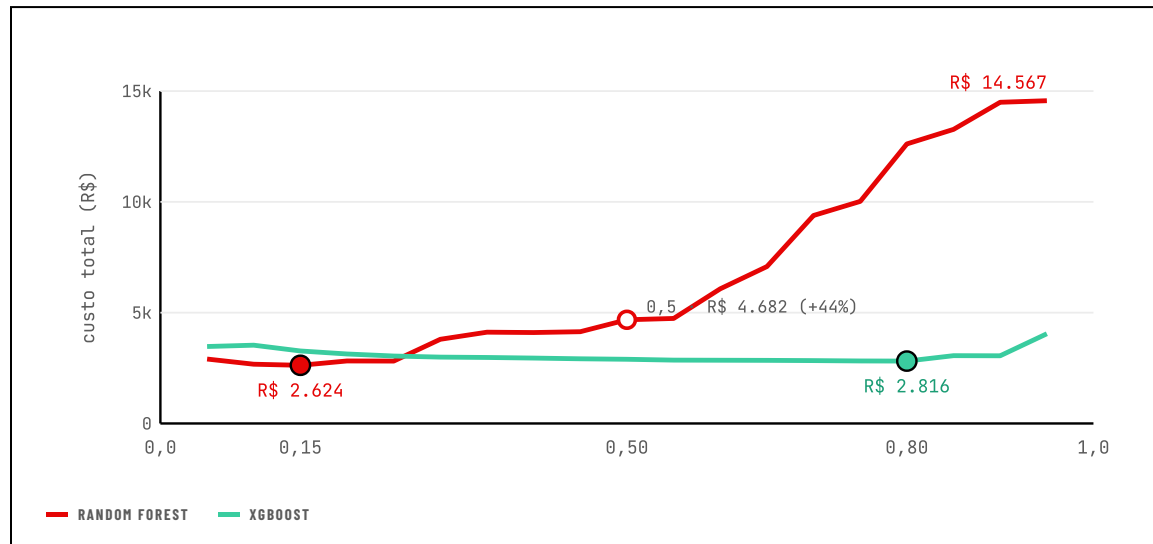
- Modelo: TP, FP, FN para cada limiar · a varredura
- Negócio: C\_FP e C\_FN, estimados e discutíveis
- Junte os dois e o limiar deixa de ser opinião

## CUSTOS SÃO HIPÓTESES

- Sempre testar a sensibilidade: e se C\_FN for 5× maior?
- Se a resposta não muda, a decisão é robusta
- Se muda, o gestor precisa decidir o custo, não o limiar

ONDE O DINHEIRO É MÍNIMO

# Custo contra *limiar*



## LEITURA

- › RF: mínimo **R\$ 2.624 em 0,15**; em 0,5 custa R\$ 4.682 · +44%
- › XGB: mínimo **R\$ 2.816 em 0,80**
- › Os degraus são fraudes caras mudando de lado
- › F1 máximo do RF era 0,30; custo mínimo é 0,15 · F1 conta fraudes, custo conta reais

Item h)

A RESTRIÇÃO QUE O CUSTO NÃO VÊ

# Quatro limiares, uma *restrição*

CORTE 0,5

## O default

Nenhum argumento além de "veio assim".

F1 MÁXIMO

## Equilíbrio

Equilibra precisão e recall. Ignora que os erros custam diferente.

CUSTO MÍNIMO

## Minimiza reais

Pode gerar mais alertas do que o time consegue triar.

CABE NO TIME

## Operacional

Menor custo entre os limiares cujo volume cabe no time. É o candidato operacional.

### A CONTA DA FILA

- › alertas = TP + FP

---

- › Se alertas > capacidade, o excedente vira fila

---

- › E fila vira falso negativo não contabilizado

### QUANDO CONFLITAM

Quando custo mínimo e capacidade conflitam, o limiar não resolve: é decisão de gestão · mais analistas, automação de triagem, ou aceitar o recall que cabe.

Item e) · os quatro limiares lado a lado

SEVERIDADE EM VEZ DE SIM OU NÃO

# Dois *limiares*, três faixas

≥ limiar alto

## Resposta automática

Bloquear, isolar, pedir segundo fator. Escolhido pela precisão · quase nenhum FP pode virar bloqueio.

entre os dois

## Fila do analista

Triagem humana. É a única faixa limitada pela capacidade do time.

< limiar baixo

## Só log

Sem ação; fica para investigação retroativa. Escolhido pelo recall · é o que se aceita perder.

A capacidade restringe só a faixa do meio. A *automação de triagem* · inclusive com IA generativa · alarga essa faixa sem contratar; voltamos a isso mais adiante no curso.

O NÚMERO QUE VOCÊ REPORTARIA

# Validação · o número *honesto*

## VALIDAÇÃO CRUZADA ESTRATIFICADA · ALEATÓRIA

- › 5 folds, shuffle, random\_state da dupla
- › Cada fold mistura início e fim de campanha
- › Boa para: escolher hiperparâmetros, medir variância
- › Ruim para: prometer desempenho ao SOC

## SPLIT TEMPORAL

- › Treina no passado, testa no futuro · 70% iniciais por dia
- › Reproduz o que o SOC vai ver na semana que vem
- › Estimativa mais baixa e mais honesta
- › Versão com vários folds: TimeSeriesSplit

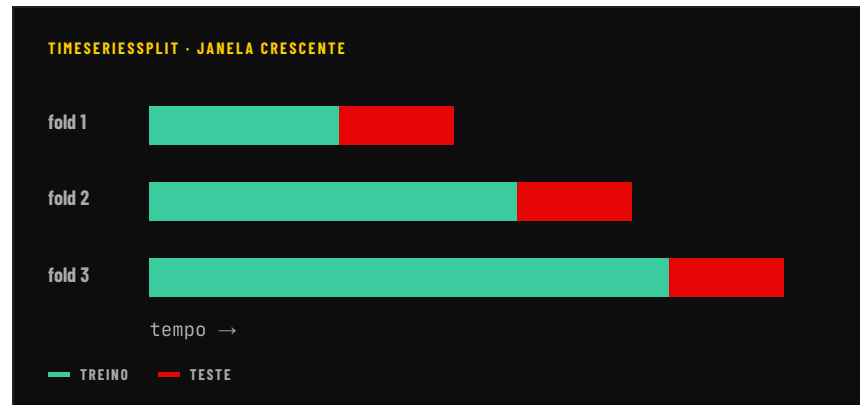
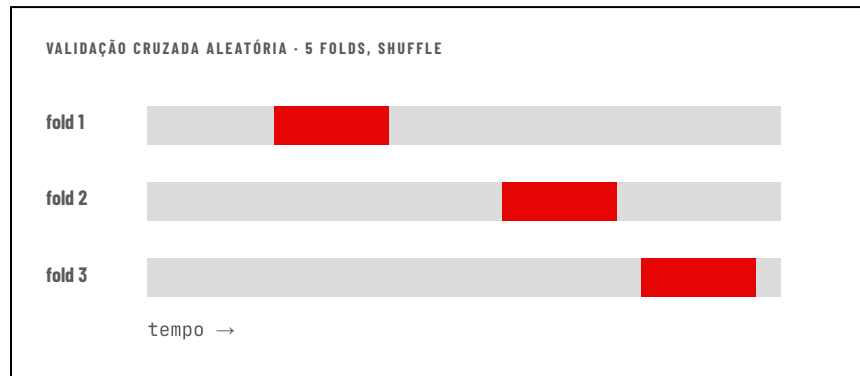
**Roteiro 2:** Bot com recall 0,96 no split aleatório e 0,16 no temporal. O mesmo modelo, a mesma classe.

A diferença entre as duas estimativas é uma medida do **drift** dentro do dataset · é o que o Roteiro 5 vai monitorar em produção.

*Item f): as duas PR-AUC, lado a lado, e a explicação do gap.*

VÁRIOS FOLDS, TODOS HONESTOS

## TimeSeriesSplit · janela *crescente*



Média e desvio como na validação cruzada, *sem treinar com o futuro*. Os primeiros folds têm pouco dado, então a variância é maior · é o regime que mais se parece com retreinar toda semana e avaliar na seguinte.

## LIMITAÇÕES E VIÉS EM MODELOS DE SEGURANÇA

# Limitações e *viés*

| FONTE DE VIÉS OU LIMITAÇÃO | COMO APARECE                                                            | ONDE ESTÁ NOS NOSSOS DADOS                        |
|----------------------------|-------------------------------------------------------------------------|---------------------------------------------------|
| Taxa-base                  | Precisão desaba quando a classe é rara                                  | 0,13% de fraudes; ataques raros no CICIDS         |
| Viés de rótulo             | O rótulo vem de um detector anterior; o que ele não viu vira "legítimo" | Fraudes não contestadas marcadas como Class = 0   |
| Origem de laboratório      | Rótulo perfeito, tráfego irreal, sem ruído de produção                  | CICIDS2017 é tráfego gerado na UNB                |
| Drift                      | O padrão muda no tempo; o modelo envelhece                              | Bot no fim da campanha; 2 dias de cartão em 2013  |
| Erro desigual              | O custo dos FP recai sobre um grupo                                     | FP concentrados em certas horas e faixas de valor |

**Item i):** recall por faixa de valor, FP por hora, e três limitações do dataset que impedem generalizar para um banco brasileiro hoje.

**Governança:** NIST AI RMF, função MAP · contexto, limitações e quem é afetado. Volta na Unidade 8.

O QUE LEVAR DESTA AULA

# Da pontuação à *decisão*

**1** O modelo entrega uma pontuação. O limiar é uma decisão de negócio com dois preços e uma capacidade.

**3** Custo mínimo e capacidade são restrições diferentes; quando conflitam, é decisão de gestão.

**5** Todo dataset tem viés de rótulo: o que o detector anterior não viu está marcado como legítimo.

**2** Precisão é o que o analista sente; a curva PR é a curva do SOC.

**4** O número honesto é o do split temporal. A validação cruzada aleatória vê o futuro.

→ A avaliação intermediária reaproveita o modelo do Roteiro 2 · itens b) a i).

LEITURAS

Chio & Freeman cap. 2 · Stallings, intrusos e falácia da taxa-base · Géron cap. 3 · NIST AI 100-2e2025

PRÓXIMA AULA

Mini-CTF de detecção com os modelos das duplas.

joaoealv@insper.edu.br